

AdScope

Modelo de seguridad de la información auditable para la gestión de campañas PPC y SEO en Amazon

Anthony Fabián Ramírez Orellana

Nery Otoniel Colorado Menchú

Sección "A" · Catedrático Omar Sagastume

Segmento: gestión de PPC y SEO para vendedores en Amazon

AdScope centraliza el trabajo que hoy se reparte en hojas de cálculo sueltas entre agencias y equipos internos que administran una o varias cuentas de venta en Amazon.

1

Segmento objetivo

Agencias y equipos internos que gestionan publicidad y SEO para múltiples ASIN en Amazon.

2

Qué centraliza

Campañas PPC, términos de búsqueda, keywords y listados de producto en un solo sistema.

3

Modelo de acceso

Un administrador y colaboradores con permisos configurables de vista o edición por módulo.

Problema de seguridad en sistemas humano-sociales y de información

1

Sin control de acceso

Cualquiera con la hoja de cálculo podía modificar inversión publicitaria o listados.

2

Sin segundo factor

La autenticación dependía solo de una contraseña de correo compartida.

3

Sin trazabilidad

Ningún registro de quién cambió qué dato de negocio, ni cuándo lo hizo.

4

Riesgo en archivos Excel

Los archivos compartidos podían ser vector de inyección de fórmulas maliciosas.

5

Sin control granular

Imposible limitar a un colaborador nuevo a solo poder ver la información.

6

Sin resiliencia

Nada detenía intentos repetidos de acceso no autorizado a una cuenta.

Solución tecnológica de seguridad implementada

1

RBAC + permisos granulares

Acceso nulo por defecto: cada módulo se habilita en modo vista o editor por usuario.

2

MFA / TOTP

Segundo factor obligatorio para administradores, con códigos de recuperación de un solo uso.

3

Bitácora de auditoría

Registro inmutable de accesos y cambios críticos, con usuario, IP y fecha.

4

Saneamiento anti-inyección

Neutraliza fórmulas maliciosas en cada archivo Excel importado al sistema.

5

Rate limiting + bloqueo

Límite de peticiones por IP y bloqueo de cuenta tras intentos fallidos repetidos.

6

Cadena de suministro

Inventario de dependencias (SBOM) y auditoría automática en cada cambio de código.

Mejoras frente al estándar ISO/IEC 27001

Dominio ISO/IEC 27001	Antes	Después
Control de acceso (A.5.15)	Sin restricciones de acceso	RBAC + permisos por módulo
Autenticación (A.5.17)	Solo contraseña de correo	MFA obligatorio (administrador)
Registro (A.8.15)	Sin bitácora de auditoría	Auditoría inmutable con IP
Continuidad (A.5.30)	Sin respaldo automático	Respaldos diarios automáticos
Disponibilidad (A.5.29)	Sin límite de peticiones	Rate limiting + bloqueo de cuenta

CLASIFICACIÓN

Vulnerabilidad o amenaza y su control

Vulnerabilidad / amenaza	Categoría CIA	Nivel	Control implementado
Fuerza bruta en el login	Confidencialidad	ALTO	Bloqueo tras 5 intentos fallidos en 15 min
Cuenta admin sin 2FA	Confidencialidad	ALTO	MFA/TOTP obligatorio + códigos de recuperación
Auto-escalamiento de rol	Confid. / Integridad	ALTO	Un admin no puede cambiar su propio rol
Inyección de fórmulas (Excel)	Integridad	MEDIO	Saneamiento de valores que inician con =, +, -, @
Acceso a módulos sin permiso	Confidencialidad	MEDIO	Permisos por módulo, acceso nulo por defecto
Saturación de la API	Disponibilidad	MEDIO	Límite de 100 solicitudes por minuto por IP

CONCLUSIÓN

Un modelo de seguridad auditable, verificable en código y alineado a la tríada CIA e ISO/IEC 27001

AdScope — Seguridad y Auditoría de Sistemas, Universidad Mariano Gálvez de Guatemala